Compliance Assessment

1. Conclusion

Overall rating: partially compliant, with one material non-compliance on a RetailHub-owned shared system.

- 12 of 14 in-scope systems meet the patch requirement on the evidence reported by the First Line (all 11 RetailHub-only systems plus CITY-RETAIL-02).
- 2 systems do not: CITY-RETAIL-01 (owned by RetailHub, internet-facing, still on PHP 8.4.26) and SMARTCITY-SVC-01 (owned by SmartCity, internet-facing, no evidence of patching).
- Assurance level: **limited**. The conclusions rest on First Line records that carry no hostnames, timestamps or command output, and no independent re-performance has been done yet (that is the Third Line's task).
- The claim that all shared systems are patched cannot be supported by the evidence on file (see section 5).

2. Scope, criteria and method

Scope. 14 systems: 6 in-store (on-premises), 5 e-commerce (cloud), and 3 shared systems from Fact Sheet 6 (CITY-RETAIL-01, CITY-RETAIL-02, SMARTCITY-SVC-01). .

Criteria.

- C1. Critical vulnerabilities must be fixed within 7 days of the fix release. Fixes were released on 21 October 2026, so the deadline is 28 October 2026.
- C2. Each system must run at least the fixed version of its branch: 8.5.12, 8.4.27, 8.3.36 or 8.2.35. PHP 8.1 and older has no fix, so the system must be upgraded or isolated.
- C3. Fact Sheet 6 control split: RetailHub patches the shared portal (CITY-RETAIL-01 and -02); SmartCity patches SMARTCITY-SVC-01. CUEC: SmartCity must supply a dated compatibility-test record, referenced in RetailHub's deployment record, before RetailHub deploys.
- C4. Evidence must be sufficient, appropriate, relevant and reliable. A management claim on its own is not enough.

Procedures performed

- P1. Compared the reported version of each system with the fixed version of its branch.
- P2. Recomputed timelines against the 28 October deadline
- P3. Cross-checked the three shared rows to Fact Sheet 6. Version, internet-facing flag and patch owner all match.
- P4. Checked the plan against the tracking table. All 9 remediation items appear in both, and every target version is the correct fixed version for its branch.
- P5. Reviewed the quality of the evidence recorded in the tracking table.

3. Results by system

System	Owner	Internet-facing	Version found	Required	Completed (days after release)	Verdict
RETAILHUB-INV-01	RetailHub	No	8.3.36	8.3.36	28 Oct (7)	Compliant, no margin
RETAILHUB-EMPL-01	RetailHub	No	8.2.35	8.2.35	28 Oct (7)	Compliant, no margin
RETAILHUB-PROM-01	RetailHub	No	8.4.27	8.4.27	Already patched, date not recorded	Compliant
RETAILHUB-SALES-01	RetailHub	No	8.5.12	8.5.12	Already patched, date not recorded	Compliant
RETAILHUB-SM-01	RetailHub	No	8.5.12	8.5.12	28 Oct (7)	Compliant, no margin
RETAILHUB-BACKUP-01	RetailHub	No	8.3.36	8.3.36	27 Oct (6)	Compliant
RETAILHUB-CATALOGUE-01	RetailHub	Yes	8.5.12	8.5.12	Already patched, date not recorded	Compliant
RETAILHUB-CLIENTAUTH-01	RetailHub	Yes	8.4.27	8.4.27	26 Oct (5)	Compliant
RETAILHUB-PAYMENT-01	RetailHub	Yes	8.4.27	8.4.27	27 Oct (6)	Compliant
RETAILHUB-SHIP-01	RetailHub	Yes	8.2.35	8.2.35	27 Oct (6)	Compliant
RETAILHUB-RETURNS-01	RetailHub	Yes	8.2.35	8.2.35	Already patched, date not recorded	Compliant
CITY-RETAIL-01	RetailHub	Yes	8.4.26	8.4.27	Not completed, deadline passed	**Non-compliant (critical)**
CITY-RETAIL-02	RetailHub	Yes	8.4.27	8.4.27	Already patched, date not recorded	Compliant
SMARTCITY-SVC-01	SmartCity	Yes	8.3.35	8.3.36	Not completed, no evidence	**Non-compliant (high)**

Totals: RetailHub-owned systems 12 of 13 compliant; SmartCity-owned systems 0 of 1. No system in scope runs PHP 8.1 or older, so no upgrade-or-isolate decision is needed. The three internet-facing e-commerce systems that were vulnerable (CLIENTAUTH, PAYMENT, SHIP) were fixed on days 5 to 6, which shows the First Line put exposed systems ahead of on-premises ones.

4. Findings

F1. CITY-RETAIL-01 is unpatched past the deadline (Critical)

Criterion. C1, C2 and C3: fix to 8.4.27 by 28 October 2026, with the SmartCity CUEC record on file.

Condition. The tracking table shows CITY-RETAIL-01 on 8.4.26, upgrade pending, with no dated SmartCity CUEC record. The fixed version has been available since 21 October.

Cause. According to the First Line, the CUEC compatibility-test record was not provided by SmartCity. The second line notes four limits on this explanation:

- RetailHub is the patch owner under Fact Sheet 6, so accountability for the deadline sits with RetailHub, not SmartCity.
- There is no evidence of when RetailHub asked SmartCity for the record, or with what due date.
- There is no evidence of an approved exception, risk acceptance, or compensating controls.
- CITY-RETAIL-02, the twin of the same portal, already runs 8.4.27, which suggests the dependency is of limited technical weight. This should be confirmed.

Effect. The system is internet-facing and exposed to unauthenticated remote code execution (CVSS v4.0 9.2). Exploitation attempts were seen before public disclosure and public proof-of-concept code exists. A WAF does not change the exposure classification under the Fact Sheet definition. The shared portal also touches SmartCity integrations, so a compromise could spread beyond RetailHub.

Recommendation.

- Send a formal written CUEC request to SmartCity with a fixed due date, and record the date sent.
- In parallel, decide between deploying 8.4.27 now with a rollback plan, or a documented risk acceptance with a named approver.
- Until patched, restrict network access to the portal to required clients and partners, and disable non-essential endpoints. Use WAF signatures only as defence in depth, never as a substitute for the patch.
- Run a compromise assessment (see F5).

F2. No evidence that SMARTCITY-SVC-01 was patched (High)

Criterion. C1 and C4: fix to 8.3.36 by 28 October 2026, shown by dated, attributable evidence.

Condition. Fact Sheet 6 records the system on 8.3.35. The tracking table shows the upgrade pending and no post-deployment version check from SmartCity.

Cause. Not known. SmartCity owns patching of this system. No contract or SLA with SmartCity was available for review.

Effect. RetailHub cannot rely on SmartCity's API being protected and carries third-party risk it cannot remediate directly.

Recommendation. Ask SmartCity, through the formal exchange, for a timestamped version check with hostname, or a patch-management export. Chase after 7 days without a reply.

F3. Priorities do not match the 7-day SLA (Low)

Criterion. C1: all critical fixes share the same 7-day limit.

Condition. The plan ranks items Low, Medium or High. INV is Low and EMPL and SM are Medium, yet all three finished on the deadline day, 28 October, with zero margin.

Cause. Priority follows asset risk rather than the vulnerability SLA.

Effect. No breach this cycle, but a small slip would have missed the deadline on three systems.

Recommendation. Align priority labels with the SLA, patch internet-facing systems first, and adopt an internal target shorter than 7 days (for example 5).

F4. Evidence is not strong enough for reasonable assurance (Medium)

Criterion. C4.

Condition. The tracking table records evidence as a text line such as post-deployment PHP version check: 8.4.27. It has no hostname, timestamp, command output, change ticket or approver. Five systems show no patch date. The advisory triage log and emergency change tickets are not referenced.

Cause. The evidence format was not defined in advance.

Effect. The second line can give only limited assurance, and the Third Line has nothing concrete to trace.

Recommendation. The First Line should attach an evidence pack per system: timestamped version output with hostname, the change ticket, and a patch-management export. The Third Line should re-perform on a sample that includes all six internet-facing e-commerce and portal systems.

F5. No evidence of a post-patch compromise check (Medium)

Criterion. Professional care: patching closes the hole but does not remove an implant already placed.

Condition. CLIENTAUTH, PAYMENT and SHIP were exposed for 5 to 6 days after the fix release, the on-premises systems for up to 7, and CITY-RETAIL-01 is still exposed. Exploitation began before disclosure. No file-integrity, web-shell or log review is recorded.

Cause. The remediation plan covers patching and access controls only.

Effect. A compromise during the exposure window could go undetected after patching.

Recommendation. Review file-integrity alerts, web-shell detection rules and access logs back to before 21 October for all internet-facing systems, starting with CITY-RETAIL-01 and the payment and authentication systems.

5. Assurance level and limitations

Level: limited assurance. Reasons:

- The evidence is self-reported by the First Line.
- The tracking table is undated.
- No interviews, tickets or independent re-performance were available.
- Internal system data is illustrative.

6. Action plan

#	Action	Owner	Deadline	Finding
1	Send formal CUEC request to SmartCity with due date; log the send date	First Line	2 business days	F1
2	Decide: deploy 8.4.27 now with rollback, or documented risk acceptance with named approver	RetailHub management, reviewed by Second Line	2 business days	F1
3	Apply interim access restrictions on CITY-RETAIL-01; WAF as defence in depth only	First Line	2 business days	F1
4	Compromise assessment of internet-facing systems	First Line with detection owner	7 days (CITY-RETAIL-01), 14 days (others)	F1, F5
5	Request dated version evidence for SMARTCITY-SVC-01 via formal exchange	First Line	Send now; chase at 7 days	F2
6	Assemble evidence pack per system	First Line	30 days	F4
7	Align priorities with the SLA; set an internal target under 7 days	First Line	30 days	F3
8	Reset the shared flag to No on the five non-shared e-commerce systems; normalise IDs	First Line	30 days	F6
9	Propose an agreement clause with SmartCity: 48-hour CUEC turnaround during critical disclosures	RetailHub management	30 days	F1, F2